



Dompé

DOCUMENTAZIONE TECNICA

Funzionamento dell'applicativo

Flussi operativi, comportamento dell'interfaccia, eventi in tempo reale e modi di degrado



Campo	Valore
Applicativo	Guest Portal — Cisco Catalyst 9800 Guest Management Desk
Documento	FUN — Funzionamento dell'applicativo
Versione	1.0
Data di emissione	18 settembre 2026
Stato	Emesso
Destinatari	IT Infrastructure, Security, Sviluppo, Service Desk
Classificazione	Uso interno
Repository di riferimento	github.com/ACF-Dompe/Centralino
Revisione del codice	main · f427890

Indice

1	Scopo del documento.....	3
1.1	A chi si rivolge.....	3
1.2	Ruoli e permessi.....	3
2	Comportamento dell'interfaccia.....	4
3	Accesso alla console.....	5
3.1	Accesso SSO e prima abilitazione	5
3.2	Amministratori riconosciuti per convenzione	6
3.3	Accesso di emergenza	6
3.4	Uscita	7
4	Scelta della sede	8
5	Registrazione di un ospite	9
5.1	Che cosa compila l'operatore	9
5.2	Che cosa succede dopo l'invio	9
5.3	Consegna delle credenziali	10
6	Ciclo di vita dell'ospite	11
6.1	Revoca.....	11
6.2	Riattivazione	11
6.3	Eliminazione	11
7	Servizi automatici	12
7.1	Il conteggio del tempo	12
7.2	La sincronizzazione con i controller	12
8	Aggiornamento in tempo reale	13
9	Amministrazione.....	14
9.1	Utenti.....	14
9.2	Sedi.....	14
9.3	Account di emergenza	14
9.4	Storico.....	15
10	Comportamento in condizioni degradate	16
11	Messaggi mostrati all'operatore	17

1 Scopo del documento

Questo documento descrive che cosa fa l'applicazione quando qualcuno la usa: quali passaggi attraversa ciascuna operazione, che cosa vede l'operatore, che cosa succede sul controller e come si comporta il sistema quando qualcosa non risponde. È il documento da leggere per capire il comportamento, non l'implementazione.

1.1 A chi si rivolge

- **Service desk e formazione:** per spiegare agli operatori che cosa fa ogni comando e perché.
- **Esercizio:** per riconoscere un comportamento atteso da un guasto.
- **Sviluppo e collaudo:** per avere la descrizione di riferimento del comportamento voluto.

1.2 Ruoli e permessi

Ruolo	Consultare	Registrare / revocare	Amministrare	Ambito
viewer	Sì	No	No	Solo le sedi concesse
operator	Sì	Sì	No	Solo le sedi concesse
admin	Sì	Sì	Sì	Tutte le sedi
break-glass	Sì	Sì	Sì (secondo il ruolo dell'account)	Tutte le sedi

Tabella 1 — Permessi per ruolo.

Vedere un comando non significa poterlo eseguire

L'interfaccia nasconde i comandi che il ruolo non consente, ma è la API a rifiutarli. Se un comando restasse visibile per un difetto dell'interfaccia, premerlo produrrebbe comunque un rifiuto 403 e nessun effetto sul controller.

2 Comportamento dell'interfaccia

All'apertura, l'applicazione interroga `/api/auth/me` e poi `/api/session/context`, e da quelle due risposte decide che cosa mostrare. Non deduce nulla: né chi è l'utente, né su quale sede sta lavorando.

• Macchina a stati dell'interfaccia e condizioni di accesso

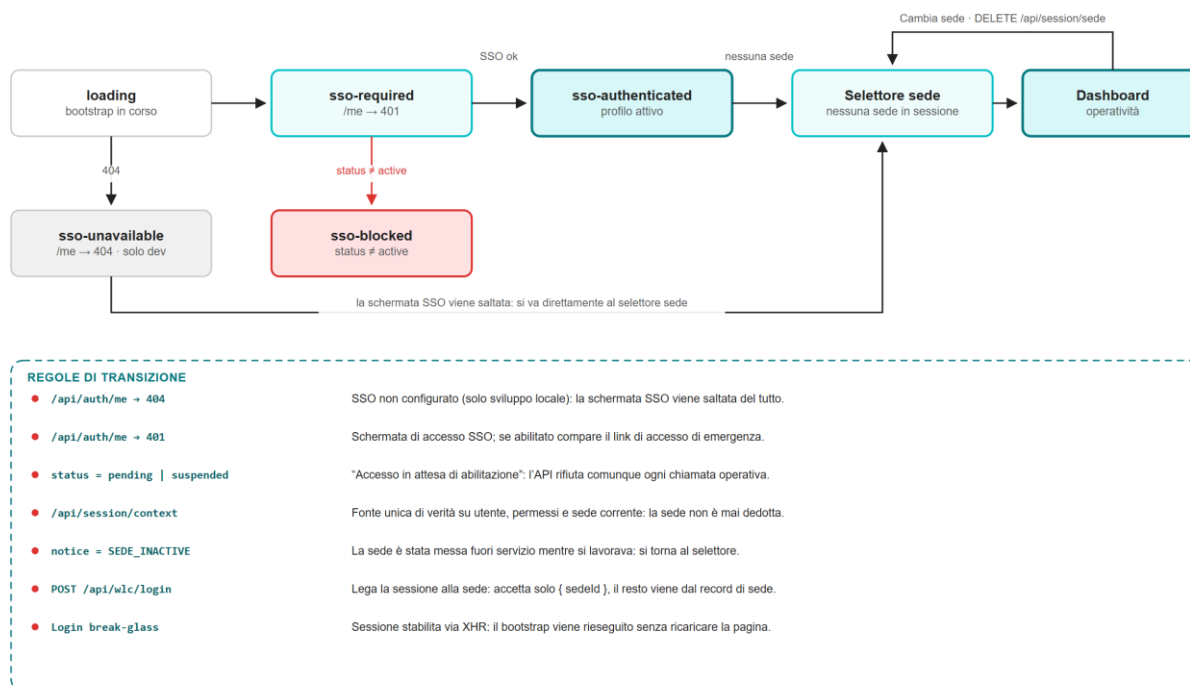


Figura 1 — Fasi dell'interfaccia e condizioni che le determinano.

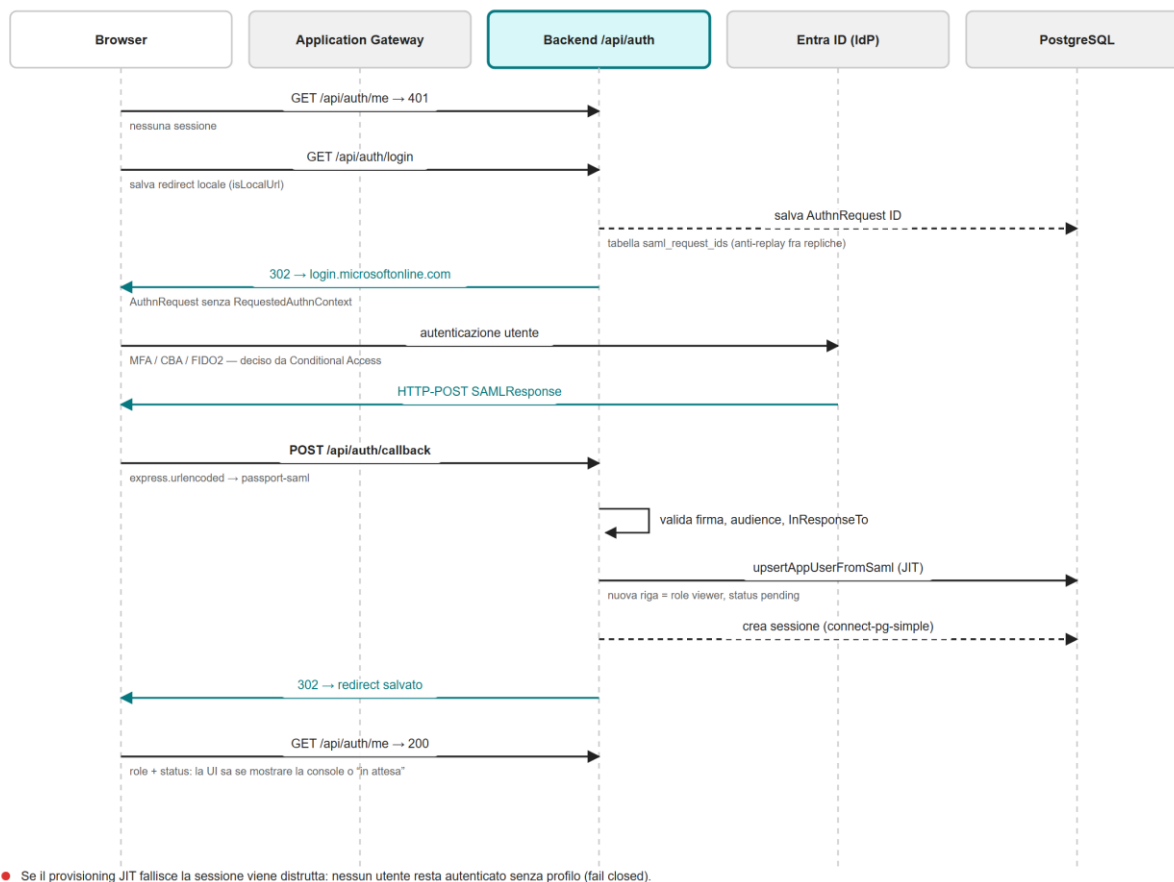
Schermata	Quando compare	Che cosa consente
Accesso SSO	<code>/api/auth/me</code> risponde 401.	Avviare l'accesso con l'account aziendale. Se abilitato, mostra il collegamento discreto all'accesso di emergenza.
Accesso in attesa di abilitazione	Autenticato ma <code>status</code> diverso da <code>active</code> .	Nulla: mostra lo UPN da comunicare all'amministratore e il comando di uscita.
Selettore sede	Autenticato e attivo, nessuna sede in sessione.	Scegliere fra le sedi in servizio concesse all'utente.
Console	Sede selezionata e connessione al controller riuscita.	Elenco ospiti, filtri, registrazione, revoca, reinvio credenziali, storico, cambio sede, uscita. Per gli amministratori anche il pannello.

Tabella 2 — Schermate dell'applicazione.

3 Accesso alla console

3.1 Accesso SSO e prima abilitazione

- Accesso SSO SAML 2.0 e provisioning just-in-time



- Se il provisioning JIT fallisce la sessione viene distrutta: nessun utente resta autenticato senza profilo (fail closed).

Figura 2 — Sequenza completa dell'accesso SSO, dalla prima richiesta al profilo utilizzabile.

PASSAGGI

1. L'operatore apre l'applicazione. Non essendoci una sessione, compare la schermata di accesso SSO.
2. Premendo «Accedi con SSO» il browser viene reindirizzato a Microsoft Entra ID. Il percorso di ritorno desiderato viene salvato in sessione, ma solo se è un percorso della stessa origine.
3. Entra ID autentica l'utente secondo le proprie regole: password, MFA, certificato, Windows Hello, FIDO2. **L'applicazione non impone il metodo.**
4. Entra ID invia la risposta SAML all'applicazione, che ne verifica firma, destinatario e corrispondenza con la richiesta emessa.
5. Al primo accesso riuscito viene creata la voce in directory: ruolo **viewer**, stato **pending**. L'utente è autenticato e non può fare nulla.
6. L'operatore vede «Accesso in attesa di abilitazione», con il proprio UPN da comunicare all'amministratore.
7. Un amministratore assegna ruolo, stato **active** e le sedi. Il cambiamento ha effetto **entro 15 secondi**, senza che l'utente debba riautenticarsi.

8. Al successivo aggiornamento della pagina compare il selettore delle sedi.

Se il provisioning fallisce

Se la creazione della voce in directory non riesce, la sessione viene **distrutta** e l'utente riportato alla schermata di accesso con un messaggio d'errore. Lasciarla in piedi produrrebbe un utente autenticato e rifiutato ovunque, senza che nulla ne spieghi il motivo.

3.2 Amministratori riconosciuti per convenzione

Un account il cui UPN ha forma `admin365-<qualcosa>@dompe.onmicrosoft.com` ottiene il ruolo di amministratore senza che nessuno lo profili. La regola è applicata sia alla scrittura in directory sia a ogni verifica dei permessi, così una modifica accidentale non può escludere un amministratore di piattaforma: il pannello mostra tali righe con l'etichetta «Admin automatico» e i campi bloccati.

Serve a raggiungere un ambiente appena installato senza passare dall'accesso di emergenza. Il vincolo sul dominio non è decorativo: senza di esso un account ospite invitato da un altro tenant potrebbe autopromuoversi.

3.3 Accesso di emergenza

È il percorso da usare **solo** quando Entra ID o il collegamento SAML non funzionano. È disattivato per impostazione predefinita e va acceso consapevolmente.

CHE COSA VEDE L'OPERATORE

1. Nella schermata di accesso SSO compare un collegamento discreto «Accesso di emergenza» — e compare **solo** se la funzione è attiva e l'indirizzo di provenienza rientra nella lista consentita.
2. Il modulo chiede nome utente e password dell'account locale.
3. In caso di rifiuto il messaggio è sempre lo stesso, qualunque sia la causa: utente inesistente, password errata, account bloccato, disabilitato o scaduto.
4. In caso di successo la sessione è stabilita senza ricaricare la pagina e la console mostra un **banner permanente** che segnala l'accesso di emergenza in corso.

Controllo	Comportamento
Funzione disattivata o indirizzo fuori lista	L'endpoint risponde 404 , non 403 : non conferma nemmeno di esistere.
Troppi tentativi dallo stesso indirizzo	429 . La finestra predefinita è di 10 tentativi ogni 15 minuti, per replica.
Troppe password errate sullo stesso account	Blocco dell'account per 15 minuti dopo 5 tentativi. Il blocco è in banca dati, quindi vale per tutte le repliche.
Durata della sessione	120 minuti per impostazione predefinita, contro le 24 ore di una sessione SSO.
Registrazione	Ogni tentativo, riuscito o meno, è registrato a livello warn . Un accesso riuscito è un evento su cui va guardato ogni volta .

Tabella 3 — Controlli sull'accesso di emergenza.

Un account bloccato non si blocca ulteriormente

Blocco, disabilitazione e scadenza sono valutati prima dell'esito della password: un tentativo continuo di indovinarla non estende il blocco, altrimenti l'operatore legittimo non potrebbe mai attenderne la fine.

3.4 Uscita

Tipo di sessione	Comportamento
SSO con Single Logout configurato	La sessione locale viene distrutta, poi il browser viene inviato all'endpoint di disconnessione di Entra ID; l'IdP conferma e riporta l'utente all'applicazione.
SSO senza SLO, oppure IdP non raggiungibile	La sessione locale viene comunque distrutta: l'utente esce dall'applicazione anche se la sessione presso l'IdP resta viva.
Emergenza	Solo uscita locale: non esiste una controparte presso l'IdP. L'evento è registrato.

Tabella 4 — *Comportamento dell'uscita.*

4 Scelta della sede

Dopo l'accesso, l'operatore sceglie la sede su cui lavorare. L'elenco contiene **solo** le sedi in servizio che gli sono state concesse: il filtro nell'interfaccia è una cortesia, il rifiuto della API è il controllo.

PASSAGGI

1. L'operatore preme sulla scheda della sede.
2. L'applicazione invia `POST /api/wlc/login` con il **solo** identificativo della sede.
3. Il server recupera indirizzo, porta e account dal record di sede, e la password da Key Vault.
4. Effettua una verifica delle credenziali verso la interfaccia di amministrazione del controller e ne registra l'esito nella diagnostica della sede.
5. Se la verifica riesce, la sessione viene legata alla sede e si apre la console.

La schermata di accesso non configura più nulla

In passato questa schermata conteneva indirizzo, porte, account e SSID del controller: ogni operatore ridigitava parametri di infrastruttura a ogni accesso, e i valori venivano rispediti al server e salvati. Era, di fatto, un modo per riconfigurare qualunque controller dalla schermata di accesso. Oggi quei parametri vivono sul record di sede e si modificano solo dal pannello di amministrazione.

QUANDO QUALCOSA NON VA

Esito	Messaggio	Chi deve intervenire
CREDENTIAL_MISSING	Password del controller non configurata per questa sede.	Amministratore: manca il segreto <code>WLC-PASSWORD-<CODICE></code> in Key Vault.
WLC_NOT_CONFIGURED	Controller non ancora configurato per questa sede.	Amministratore: la sede esiste ma è priva di indirizzo.
SEDE_INACTIVE	Sede disattivata.	Amministratore: la sede è stata messa fuori servizio.
sede_forbidden	Non sei abilitato a questa sede.	Amministratore: concessione mancante.
Controller irraggiungibile	Messaggio specifico per timeout, connessione rifiutata, nome non risolto o certificato rifiutato.	Rete / infrastruttura. Il messaggio nomina la causa e, dove pertinente, la variabile da cambiare.

Tabella 5 — Esiti possibili della connessione a una sede.

Cambia sede (`DELETE /api/session/sede`) libera la sede mantenendo la sessione applicativa: si torna al selettore senza rifare l'accesso. Se una sede viene messa fuori servizio mentre qualcuno ci sta lavorando, la sessione viene liberata automaticamente e l'operatore riportato al selettore con un avviso.

5 Registrazione di un ospite

• Registrazione di un ospite e consegna delle credenziali

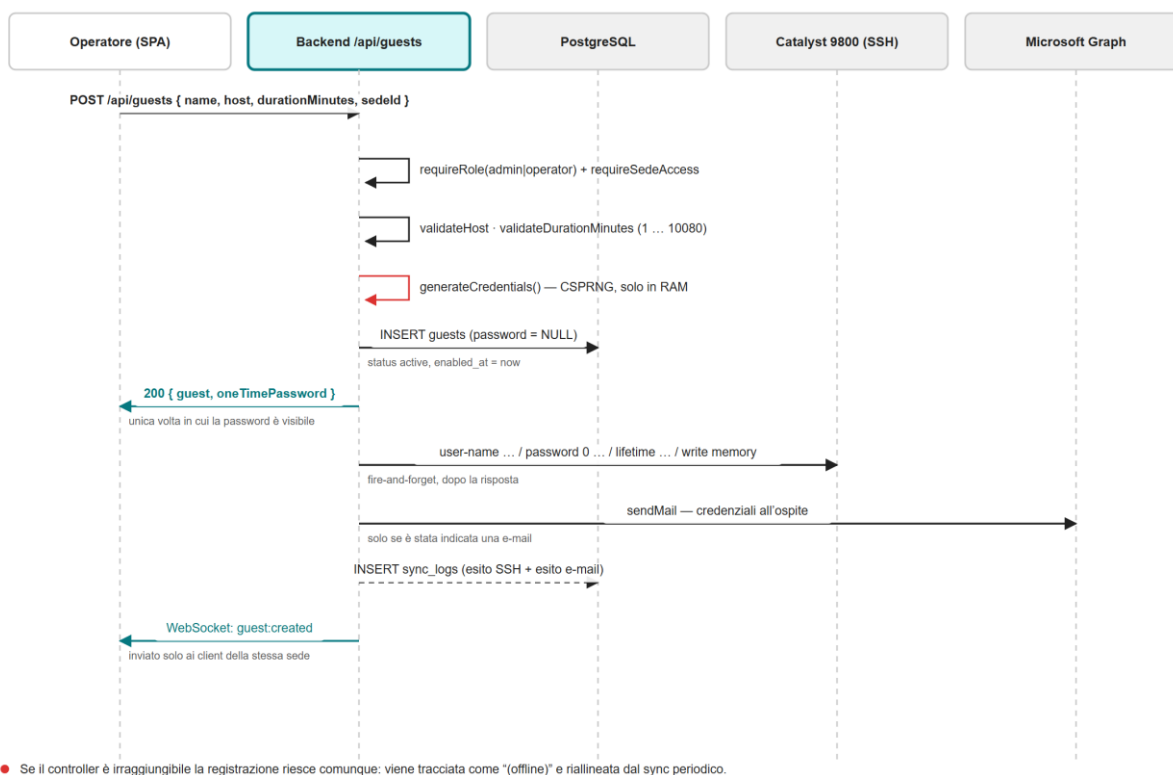


Figura 3 — Registrazione: validazione, generazione della credenziale, provisioning sul controller e consegna.

5.1 Che cosa compila l'operatore

Campo	Obbligatorio	Note
Nome	Sì	Da qui si ricava lo username sul controller.
Referente interno	Sì	Chi ospita la visita; compare nel messaggio all'ospite.
Durata	Sì	Valori predefiniti: 30 minuti, 2 ore, 4 ore, 8 ore, 1 giorno, 1 settimana. In alternativa una data e ora di fine.
E-mail	No	Se presente, le credenziali vengono inviate automaticamente.
Telefono	No	Raccolto, non utilizzato: il canale SMS è dormiente.
Azienda	No	Predefinito «Ospite Individuale».
Note	No	Annotazione libera.

Tabella 6 — Campi del modulo di registrazione.

La durata massima è **una settimana**, ed è imposta dal server oltre che dal modulo: il limite deve valere anche per una richiesta che non passi dall'interfaccia.

5.2 Che cosa succede dopo l'invio

1. Il server verifica ruolo e abilitazione alla sede, poi valida i dati.

2. Genera username e password con un generatore crittografico. L'alfabeto della password esclude I, O, l e 0, perché queste credenziali vengono spesso dettate o trascritte.
3. Registra l'ospite in banca dati **senza la password**, in stato attivo, con l'istante di inizio del conteggio.
4. Risponde subito all'operatore con la password: è l'unica volta in cui sarà visibile.
5. Nel frattempo, e senza far attendere l'operatore, spinge la credenziale sul controller della sede via SSH e salva la configurazione.
6. Se è stato indicato un indirizzo, invia il messaggio con le credenziali tramite Microsoft Graph.
7. Registra entrambi gli esiti nello storico e propaga l'evento alle altre postazioni della stessa sede.

```
username: g.mrossi417
password: DOMPE-k7Rm2xQp
```

Comandi inviati al controller:

```
user-name g.mrossi417
password 0 DOMPE-k7Rm2xQp
type network-user description Guest-User guest-user lifetime year 0 month 0 day 0 hour 4 minute 0
second 0
do write memory
```

5.3 Consegna delle credenziali

Canale	Stato	Comportamento
Schermo	Attivo	La password compare una sola volta, con un comando di copia e un codice QR Wi-Fi che l'ospite può inquadrare.
E-mail	Attivo	Messaggio HTML e testo con SSID, username, password, scadenza e referente. Inviato tramite Microsoft Graph.
Stampa	Attivo	Stampa del riquadro credenziali dalla stessa schermata.
SMS	Dormiente	Configurazione presente a schema, nessun provider impostato, funzione non esposta.

Tabella 7 — Canali di consegna delle credenziali.

La password non è recuperabile

Chiusa la finestra, la password non è più leggibile da nessuna parte: non è mai stata scritta. Se l'ospite la perde, si usa **Reinvia credenziali**, che ne genera una nuova, la spinge sul controller sostituendo la precedente e la invia di nuovo. Lo username resta lo stesso.

6 Ciclo di vita dell'ospite

● Ciclo di vita dell'account ospite

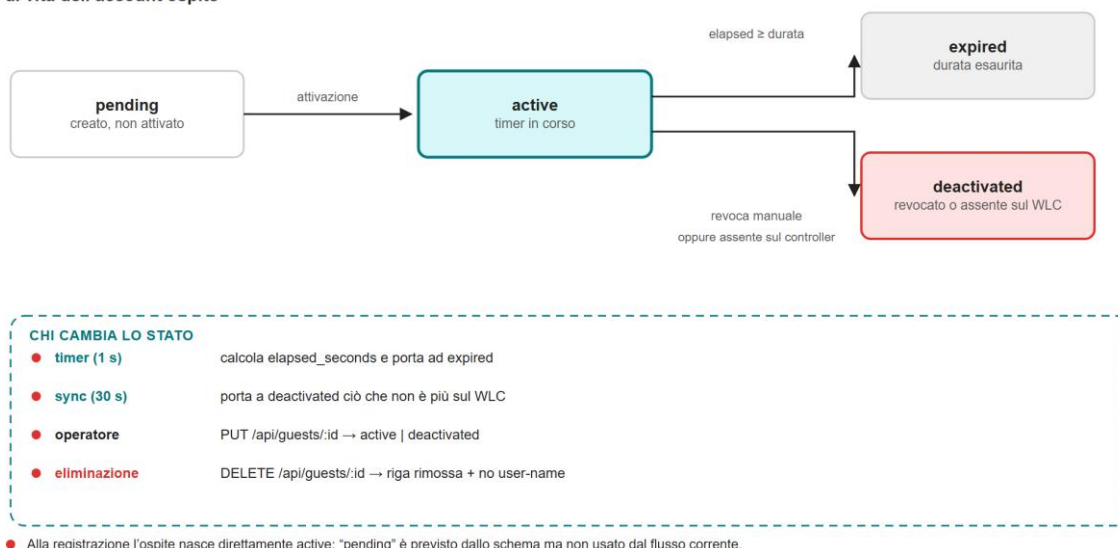


Figura 4 — Stati di un account ospite e transizioni possibili.

Stato	Significato	Sul controller
active	Accesso concesso, conteggio in corso.	L'utente esiste con la propria durata.
expired	La durata è esaurita.	Il controller applica la propria scadenza; l'applicazione registra lo stato.
deactivated	Revocato manualmente, oppure non più presente sul controller.	L'utente è stato rimosso.
pending	Previsto dallo schema, non utilizzato dal flusso corrente.	—

Tabella 8 — Stati di un account ospite.

6.1 Revoca

Portare un ospite a «disattivato» invia `no user-name <username>` al controller della **sua** sede e salva la configurazione. Il comando non viene mai inviato a un controller diverso: mandarlo altrove cancellerebbe un account reale in un'altra sede.

6.2 Riattivazione

Riportare un ospite a «attivo» aggiorna lo stato e fa ripartire il conteggio, ma **non** ripristina la credenziale sul controller: la password non è mai stata conservata. L'operazione va completata con «Reinvia credenziali», e lo storico registra esplicitamente questa condizione.

6.3 Eliminazione

Eliminare un ospite rimuove la riga dalla banca dati e invia `no user-name` al controller. È l'unica operazione che cancella dati in modo definitivo dal punto di vista dell'operatore.

7 Servizi automatici

• Servizi di background: timer e sincronizzazione con i controller

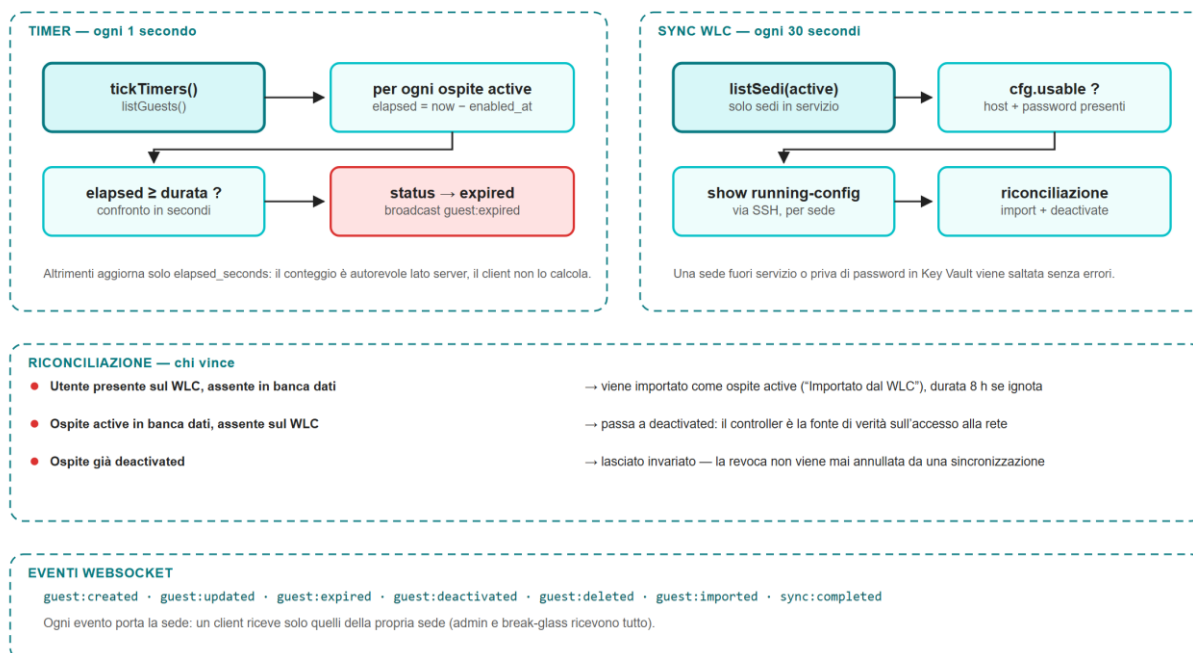


Figura 5 — Timer e sincronizzazione: cadenze e regole di riconciliazione.

7.1 Il conteggio del tempo

Il tempo trascorso è calcolato **dal server**, ogni secondo, a partire dall'istante di abilitazione. Il client non lo calcola: mostra ciò che riceve. Quando il tempo trascorso raggiunge la durata concessa, lo stato passa a «scaduto» e l'evento raggiunge immediatamente le postazioni della sede.

7.2 La sincronizzazione con i controller

Ogni trenta secondi, per ciascuna sede in servizio, l'applicazione legge la configurazione del controller e la confronta con la propria banca dati.

Situazione	Azione	Perché
Utente presente sul controller, assente in banca dati	Viene importato come ospite attivo, con nota «Importato dal WLC» e durata di 8 ore se non ricavabile.	Un accesso concesso direttamente sul controller deve essere visibile in console, non invisibile.
Ospite attivo in banca dati, assente sul controller	Passa a «disattivato».	Il controller è la fonte di verità sull'accesso alla rete: se lì non c'è, l'accesso non esiste.
Ospite già disattivato	Lasciato invariato.	Una revoca non viene mai annullata da una sincronizzazione.
Sede fuori servizio, senza indirizzo o senza password	Saltata, senza errori.	Non è un guasto: è una sede che non è pronta o non è in uso.

Tabella 9 — Regole di riconciliazione.

La conseguenza pratica è che una modifica fatta direttamente sul controller compare in console **entro trenta secondi**, non immediatamente.

8 Aggiornamento in tempo reale

La console mantiene un canale WebSocket verso il server. L'apertura del canale è autenticata con la stessa sessione della API e **autorizzata**: un utente sospeso perde il canale, non lo conserva fino alla scadenza del cookie.

Evento	Quando	Effetto in console
<code>guest:created</code>	Un ospite è stato registrato.	Notifica e aggiornamento dell'elenco.
<code>guest:updated</code>	Lo stato di un ospite è cambiato.	Aggiornamento dell'elenco.
<code>guest:expired</code>	La durata è esaurita.	Notifica, segnale acustico, aggiornamento.
<code>guest:deactivated</code>	Revocato, o sparito dal controller.	Notifica, segnale acustico, aggiornamento.
<code>guest:deleted</code>	Eliminato.	Notifica e aggiornamento.
<code>guest:imported</code>	Importato dalla sincronizzazione.	Notifica e aggiornamento.
<code>sync:completed</code>	Una sincronizzazione di sede è terminata.	Aggiornamento dell'elenco.

Tabella 10 — *Eventi in tempo reale.*

Gli eventi non attraversano le sedi

Ogni evento porta con sé la sede, e una connessione riceve solo quelli della sede su cui sta lavorando. I nomi degli ospiti sono dati personali e non c'è ragione che un operatore di Milano sappia chi si è appena connesso a Napoli. Amministratori e sessioni di emergenza ricevono tutto.

Se il canale cade, la console continua a funzionare: un aggiornamento completo ogni trenta secondi tiene l'elenco corretto, solo meno reattivo. Il client tenta di riconnettersi con attesa crescente fino a dieci volte.

9 Amministrazione

9.1 Utenti

1. Il pannello elenca le voci in directory, filtrabili per stato e per testo.
2. Per ciascuna si impostano ruolo, stato e sedi concesse.
3. La modifica ha effetto entro 15 secondi su tutte le repliche, senza che l'utente debba riautenticarsi.
4. Eliminare una voce ne rimuove anche le concessioni. La voce viene ricreata, **bloccata**, al successivo accesso dell'utente.

Due protezioni contro l'auto-esclusione

La API rifiuta a un amministratore di declassare sé stesso e rifiuta di sospendere o declassare l'ultimo amministratore attivo. L'alternativa sarebbe un'applicazione che nessuno può più amministrare: ogni utente resterebbe bloccato e nessuno potrebbe sbloccarlo.

9.2 Sedi

Operazione	Note
Creazione	La sede nasce fuori servizio : si configura con calma e la si mette in servizio quando è pronta.
Modifica	Indirizzo, porte, account, SSID, anagrafica. Il codice non è modificabile : è ciò che risolve il segreto in Key Vault.
In servizio / fuori servizio	Una sede fuori servizio sparisce dal selettore e viene saltata dalla sincronizzazione.
Prova di connessione	Verifica la raggiungibilità del controller e aggiorna la diagnostica. È solo diagnostica : non tocca la sessione di chi la esegue.
Eliminazione	Rifiutata finché esistono ospiti collegati alla sede.

Tabella 11 — Operazioni sulle sedi.

Il pannello mostra, per ogni sede, se la password del controller risulta configurata e il **nome** della variabile e del segreto da chiedere al team di piattaforma. Il valore non è mai mostrato.

9.3 Account di emergenza

Dal pannello si possono **abilitare**, **disabilitare** e **sbloccare** gli account di emergenza, e consultarne lo stato. Non si possono creare, né si può ruotarne la password: quelle operazioni vivono solo nella riga di comando.

Perché la creazione resta fuori dall'applicazione

Una sessione amministrativa compromessa non deve poter coniare una credenziale che aggira Entra ID e le sue politiche di accesso condizionale. Creare un account di emergenza richiede accesso shell al container.

9.4 Storico

Lo storico mostra le ultime operazioni verso i controller e verso il servizio di posta, con esito e destinazione. È accessibile a operatori e amministratori; la cancellazione è riservata agli amministratori.

10 Comportamento in condizioni degradate

Il sistema è costruito perché un guasto in un componente non ne blocchi altri più del necessario.

Guasto	Che cosa continua a funzionare	Che cosa no	Che cosa vede l'operatore
Controller di una sede irraggiungibile	Accesso, consultazione, registrazione in banca dati, altre sedi.	Provisioning e revoca su quella sede; la sincronizzazione la salta.	Messaggio specifico sulla causa; le operazioni compaiono nello storico come «(offline)».
Entra ID non disponibile	Le sessioni già aperte; l'accesso di emergenza, se abilitato.	Nuovi accessi SSO.	La schermata di accesso SSO resta, con l'eventuale collegamento di emergenza.
Certificato SAML inutilizzabile	L'accesso di emergenza.	Tutte le rotte SSO, che rispondono 501.	Schermata di accesso SSO con messaggio esplicito; il motivo è nei log di avvio.
PostgreSQL non disponibile	Nulla di significativo.	Autenticazione, sessioni, ogni operazione.	<code>/api/readyz</code> risponde 503; le richieste falliscono.
Microsoft Graph non disponibile	Registrazione e provisioning.	L'invio automatico delle credenziali.	La password resta visibile a schermo per la consegna manuale; lo storico registra il fallimento.
Canale WebSocket interrotto	Tutto.	L'aggiornamento immediato.	La console si aggiorna ogni trenta secondi; il client riprova a connettersi.
Risoluzione dei permessi fallita	Nulla per l'utente coinvolto.	La richiesta.	503 con invito a riprovare. Mai un ruolo assunto per difetto.

Tabella 12 — Comportamento in condizioni degradate.

11 Messaggi mostrati all'operatore

I messaggi sono pensati per indicare **chi** deve intervenire, non solo che qualcosa è andato storto.

Situazione	Messaggio	Azione
Utente non ancora abilitato	«Utente non ancora abilitato. Un amministratore deve profilare il tuo account.»	Comunicare il proprio UPN a un amministratore.
Utente sospeso	«Accesso sospeso. Contatta un amministratore.»	Rivolgersi a un amministratore.
Ruolo insufficiente	«Non hai i permessi necessari per questa operazione.»	Richiedere l'abilitazione al ruolo adeguato.
Sede non concessa	«Non sei abilitato a questa sede.»	Richiedere la concessione della sede.
Nessuna sede selezionata	«Nessuna sede selezionata.»	Tornare al selettore.
Sede disattivata	«Sede disattivata.»	L'amministratore deve rimetterla in servizio.
Password del controller assente	«Password WLC non configurata per questa sede.»	L'amministratore deve richiedere il segreto al team di piattaforma.
Certificato del controller rifiutato	Messaggio che distingue il rifiuto del certificato dalla irraggiungibilità e nomina la variabile coinvolta.	Installare un certificato attendibile, o accettare consapevolmente la deroga.
Autorizzazione non disponibile	«Servizio di autorizzazione non disponibile. Riprova tra poco.»	Riprovare; se persiste, verificare il database.
Ospite senza indirizzo	«L'ospite non ha un indirizzo e-mail — impossibile inviare le credenziali.»	Consegnare la password a schermo o su carta.

Tabella 13 — Messaggi principali e azione suggerita.